



**OFICINA DE SOLUÇÕES
PROFISSIONAIS**

ORIENTAÇÕES

OFICINA DE SOLUÇÕES PROFISSIONAIS

Disciplina: Segurança e Auditoria de Sistemas
Unidade: 4- Auditoria de Sistemas e Segurança

Encontro 4 – Aprendizagem entre pares

Neste encontro, você estudará entre pares todos os conteúdos abordados na disciplina, e compartilhará o resultado de aprendizagem com seus colegas de turma. Você terá a oportunidade de aprender com o outro. Você também trabalhará sua comunicação e autoconfiança.

Você deverá concluir a atividade e apresentá-la ao final do encontro.

1. Objetivo da Atividade:

Elaborar um planejamento de auditoria de sistemas a partir de um cenário organizacional real, identificando objetivos, riscos prioritários e métodos de coleta de evidências adequados ao contexto apresentado.

2. Descrição da Atividade

O Banco FinançaSegura é uma instituição financeira de médio porte que opera com sistema de internet banking, aplicativo mobile e rede interna para funcionários. Nos últimos seis meses, a instituição registrou três ocorrências preocupantes: clientes relataram tentativas de acesso não autorizado às suas contas; um funcionário do setor de TI foi demitido e, dias depois, constatou-se que suas credenciais ainda estavam ativas no sistema; e um relatório interno indicou que os logs de acesso ao banco de dados de clientes não foram gerados durante uma janela de 72 horas por falha de configuração. O Banco não passou por auditoria de sistemas nos últimos dois anos e não possui um plano formal de auditoria documentado. A diretoria determinou que uma equipe de auditoria interna realize um processo completo antes do fechamento do trimestre.

- **Objetivos e escopo da auditoria:** definem o que será avaliado e por quê, delimitando as áreas prioritárias com base nos riscos identificados no contexto organizacional.
- **Avaliação de riscos:** identifica as ameaças e vulnerabilidades que mais impactam a organização, permitindo priorizar onde concentrar os esforços de auditoria.
- **Coleta de evidências:** envolve os procedimentos utilizados para verificar os controles de segurança na prática — como revisão de logs, entrevistas com responsáveis técnicos e análise de documentação.

- Avaliação de controles internos: verifica se os mecanismos existentes de segurança são eficazes e estão alinhados a padrões como a ISO 27001, identificando lacunas e pontos de melhoria.

Com base no cenário do Banco FinançaSegura e nos conceitos apresentados, elabore um planejamento de auditoria considerando os seguintes elementos:

- Objetivos e escopo: defina o que a auditoria pretende verificar e quais sistemas, processos ou áreas serão avaliados, com base nas ocorrências descritas no cenário.
- Riscos prioritários: identifique os três principais riscos de segurança presentes no cenário e justifique a priorização de cada um.
- Métodos de coleta de evidências: indique quais métodos serão utilizados para verificar cada risco identificado (ex.: análise de logs, entrevistas, revisão documental, testes técnicos).
- Recomendação inicial: com base nos riscos levantados, elabore ao menos uma recomendação de melhoria para cada risco identificado, indicando qual controle deve ser implementado ou corrigido.

Organize o planejamento de forma estruturada, respondendo a cada um dos quatro elementos acima para o contexto do Banco FinançaSegura.

3. Etapas para Realização

Leia o cenário com atenção e defina os objetivos da auditoria: o que precisa ser verificado e por que, com base nas três ocorrências descritas;

Identifique e priorize os três principais riscos de segurança presentes no cenário, justificando cada escolha com base em sua gravidade e potencial de impacto para o banco;

Para cada risco identificado, indique qual método de coleta de evidências será utilizado e explique por que esse método é o mais adequado para verificar aquele risco específico;

Elabore uma recomendação de melhoria para cada risco, indicando qual controle deve ser implementado ou corrigido para reduzir a exposição da instituição.

GABARITO:

Parte 1 — Objetivos e Escopo da Auditoria

Objetivos:

- Verificar a eficácia dos controles de acesso ao sistema de internet banking e aplicativo mobile
- Avaliar o processo de gestão de identidades, especialmente o procedimento de desativação de contas no desligamento de funcionários
- Verificar a integridade e continuidade do sistema de geração de logs de acesso ao banco de dados de clientes
- Avaliar o alinhamento dos controles de segurança existentes com boas práticas e regulamentações aplicáveis ao setor financeiro

Escopo: A auditoria abrangerá os sistemas de autenticação e controle de acesso do internet banking e do aplicativo mobile; o processo de gestão do ciclo de vida de contas de usuários internos (criação, alteração e desativação); a infraestrutura de geração, armazenamento e monitoramento de logs de acesso; e os controles internos relacionados à segurança da informação, considerando o período dos últimos seis meses.

Parte 2 — Riscos Prioritários

Risco 1 — Credenciais de ex-funcionário ativas após demissão Prioridade: Alta Esse é o risco mais crítico porque representa uma vulnerabilidade ativa e confirmada: sabe-se que o acesso existe e que não deveria existir. Um ex-funcionário com acesso legítimo ao sistema interno pode visualizar dados de clientes, realizar operações não autorizadas ou, em caso de intenção maliciosa, causar danos significativos sem deixar rastro imediato. No setor financeiro, esse tipo de falha pode gerar responsabilidade legal e danos reputacionais graves.

Risco 2 — Falha na geração de logs por 72 horas Prioridade: Alta A ausência de logs durante 72 horas compromete toda a capacidade de rastreabilidade da organização nesse período. Não é possível saber o que ocorreu, quem acessou o quê ou se houve operações fraudulentas. Além de ser uma falha técnica de controle, representa um risco de conformidade: reguladores do setor financeiro exigem rastreabilidade contínua das operações. A gravidade é ampliada porque a falha pode ter coincidido com as tentativas de acesso não autorizado.

Risco 3 — Tentativas de acesso não autorizado às contas de clientes Prioridade: Alta Ataques ao internet banking são o vetor de maior exposição de uma instituição financeira ao público externo. As tentativas relatadas pelos clientes indicam que há ataque em andamento — seja por força bruta, credential stuffing ou phishing. A ausência de mecanismos de bloqueio eficazes ou de autenticação adicional agrava o risco de comprometimento real de contas.

Parte 3 — Métodos de Coleta de Evidências

Risco 1 — Credenciais de ex-funcionário ativas

Método**Justificativa**

Revisão documental da lista de usuários ativos	Permite cruzar os logins ativos no sistema com o registro de desligamentos de RH, identificando contas que deveriam ter sido desativadas
Entrevistas com responsáveis de TI e RH	Permite entender se existe um processo formal de desativação de contas e por que ele falhou neste caso
Análise de logs de acesso do período	Verifica se o ex-funcionário utilizou as credenciais após o desligamento

Risco 2 — Falha na geração de logs**Método****Justificativa**

Análise técnica da configuração do sistema de logs	Identifica a causa raiz da falha — se foi erro de configuração, falta de monitoramento ou problema de infraestrutura
Teste de funcionamento dos mecanismos de alerta	Verifica se existem alertas configurados para detectar falhas no sistema de logs e por que não dispararam
Revisão documental das políticas de auditoria	Verifica se existe política formal que exija continuidade e integridade dos registros de log

Risco 3 — Tentativas de acesso não autorizado**Método****Justificativa**

Análise de logs de autenticação do internet banking e app mobile	Permite identificar padrões de tentativas (horários, IPs, volume), avaliar a frequência dos ataques e verificar se houve acessos bem-sucedidos
Avaliação dos controles de autenticação existentes	Verifica se há autenticação multifator, bloqueio após tentativas fracassadas e detecção de comportamento anômalo
Testes técnicos de segurança (varredura de vulnerabilidades)	Identifica se existem vulnerabilidades técnicas exploráveis nos sistemas de acesso público

Parte 4 — Recomendações de Melhoria

Risco 1 — Credenciais de ex-funcionário ativas Implementar um processo formal e documentado de gestão do ciclo de vida de contas de usuários, integrando o RH ao setor de TI. No momento do desligamento de qualquer funcionário, deve haver um checklist obrigatório que inclua a desativação imediata de todos os acessos — sistemas internos, VPN, e-mail corporativo e aplicativos. Recomenda-se também auditoria periódica (mensal) da lista de usuários ativos, cruzando com o quadro funcional vigente.

Risco 2 — Falha na geração de logs Implementar monitoramento contínuo e automatizado da integridade do sistema de logs, com alertas disparados em tempo real caso a geração de registros seja interrompida. O sistema de logs deve ter redundância — armazenamento em mais de um servidor ou serviço — para evitar perda total de rastreabilidade por falha de um

único componente. A política de auditoria deve definir formalmente os requisitos de continuidade e retenção dos logs.

Risco 3 — Tentativas de acesso não autorizado Implementar autenticação multifator (MFA) obrigatória para todos os acessos ao internet banking e ao aplicativo mobile. Configurar bloqueio temporário de conta após um número definido de tentativas de login malsucedidas e implementar detecção de comportamento anômalo (ex.: múltiplas tentativas de IPs distintos, acessos fora do horário habitual). Comunicar os clientes afetados sobre as tentativas detectadas, conforme exige a LGPD em casos de incidentes com potencial impacto.